



CSPy
SECURITY SCANNER

2026-06-29 10:42 UTC
vaultocean.com

SECURITY HEADER AUDIT



localhost

http://localhost:5000/signup.html

1

CRITICAL

1

HIGH

3

MEDIUM

3

LOW

01 — OVERVIEW

Executive Summary

This site received a security grade of **C** (55/100), classified as *Fair*. **1 critical issue** require immediate remediation. **1 high-severity issue** should be addressed soon.

1

CRITICAL

1

HIGH

3

MEDIUM

3

LOW

6

INFO

MULTI-ENGINE CONSENSUS · ±32 SPREAD

CSPY

C

55/100

GOOGLE CSP EVALUATOR

F

37/100

MOZILLA OBSERVATORY

B-

69/100

02 — ACTION PLAN

Recommendations

01 **CRITICAL** **Content-Security-Policy** **A03:2021**

`'unsafe-inline'` allows arbitrary inline scripts — XSS protection effectively disabled.

Fix Remove `'unsafe-inline'`. Move inline scripts to external files, or use per-request nonces (`'nonce-<random>'`) or sha256 hashes.

```
# nginx
add_header Content-Security-Policy "default-src 'self'; script-src 'self';
style-src 'self' 'unsafe-inline'; img-src 'self' data:; object-src 'none'; base-
uri 'self'; frame-ancestors 'none'; upgrade-insecure-requests;" always;
```

02 **HIGH** Strict-Transport-Security **A02:2021**

Strict-Transport-Security header missing.

Fix — Add `Strict-Transport-Security: max-age=63072000; includeSubDomains; preload` (2 years).

```
# nginx
add_header Strict-Transport-Security "max-age=63072000; includeSubDomains;
preload" always;
# Also ensure HTTP redirects to HTTPS:
server {
    listen 80;
    return 301 https://$host$request_uri;
}
```

03 **MEDIUM** Content-Security-Policy **A03:2021**

base-uri not set — attackers can inject a `` tag to redirect relative URLs.

Fix — Add `base-uri 'self'` or `none`.

```
# nginx
add_header Content-Security-Policy "default-src 'self'; script-src 'self';
style-src 'self' 'unsafe-inline'; img-src 'self' data;; object-src 'none'; base-
uri 'self'; frame-ancestors 'none'; upgrade-insecure-requests;" always;
```

04 **MEDIUM** Content-Security-Policy **A04:2021**

frame-ancestors not set — relies on legacy X-Frame-Options.

Fix — Add `frame-ancestors 'none'` (or `self`).

```
# nginx
add_header Content-Security-Policy "default-src 'self'; script-src 'self';
style-src 'self' 'unsafe-inline'; img-src 'self' data;; object-src 'none'; base-
uri 'self'; frame-ancestors 'none'; upgrade-insecure-requests;" always;
```

05 **MEDIUM** Information Disclosure **A06:2021**

`server: Werkzeug/3.1.8 Python/3.14.6` — exposes version number, enabling targeted exploit searches.

Fix — Remove or generalize the `server` header. Version exposure aids attackers in finding CVEs.

```
# nginx
server_tokens off;
# Also consider:
more_clear_headers Server; # requires ngx_http_headers_more_filter_module
```

06 **LOW** Content-Security-Policy **A03:2021**

object-src not locked to `none`.

Fix — Use `object-src 'none'` unless you specifically need plugins.

```
# nginx
add_header Content-Security-Policy "default-src 'self'; script-src 'self';
style-src 'self' 'unsafe-inline'; img-src 'self' data:; object-src 'none'; base-
uri 'self'; frame-ancestors 'none'; upgrade-insecure-requests;" always;
```

07 **LOW** Content-Security-Policy **A03:2021**

form-action not set — forms can submit anywhere.

Fix — Add `form-action 'self'`.

```
# nginx
add_header Content-Security-Policy "default-src 'self'; script-src 'self';
style-src 'self' 'unsafe-inline'; img-src 'self' data:; object-src 'none'; base-
uri 'self'; frame-ancestors 'none'; upgrade-insecure-requests;" always;
```

08 **LOW** **Referrer-Policy** **A02:2021**

Referrer-Policy missing — browser default leaks full URLs to other origins.

Fix — Add `Referrer-Policy: strict-origin-when-cross-origin`.

```
# nginx
add_header Referrer-Policy "strict-origin-when-cross-origin" always;
```

09 **INFO** **Content-Security-Policy** **A03:2021**

Consider enabling `upgrade-insecure-requests` to auto-rewrite http:// → https://.

Fix — Add `upgrade-insecure-requests` (no value).

```
# nginx
add_header Content-Security-Policy "default-src 'self'; script-src 'self';
style-src 'self' 'unsafe-inline'; img-src 'self' data:; object-src 'none'; base-
uri 'self'; frame-ancestors 'none'; upgrade-insecure-requests;" always;
```

10 **INFO** **Content-Security-Policy** **A03:2021**

No CSP reporting endpoint configured — violations are invisible.

Fix — Add `report-to` with a Reporting API group, or legacy `report-uri`.

```
# nginx
add_header Content-Security-Policy "default-src 'self'; script-src 'self';
style-src 'self' 'unsafe-inline'; img-src 'self' data:; object-src 'none'; base-
uri 'self'; frame-ancestors 'none'; upgrade-insecure-requests;" always;
```

11 INFO Permissions-Policy A05:2021

Permissions-Policy missing — features (camera, mic, geolocation, etc.) inherit defaults.

Fix — Add e.g. `Permissions-Policy: camera=(), microphone=(), geolocation=()` to lock unused features down.

```
# nginx
add_header Permissions-Policy "camera=(), microphone=(), geolocation=(),
payment=(), usb=(), interest-cohort=()" always;
```

12 INFO Cross-Origin-Opener-Policy A05:2021

Cross-Origin-Opener-Policy missing — cross-window attacks possible.

Fix — Add `Cross-Origin-Opener-Policy: same-origin`.

```
# nginx
add_header Cross-Origin-Opener-Policy "same-origin" always;
```

13 INFO Cross-Origin-Embedder-Policy A05:2021

Cross-Origin-Embedder-Policy missing — required for SharedArrayBuffer/cross-origin isolation.

Fix — Add `Cross-Origin-Embedder-Policy: require-corp` if you need cross-origin isolation.

14 INFO Cross-Origin-Resource-Policy A05:2021

Cross-Origin-Resource-Policy missing.

Fix — Add `Cross-Origin-Resource-Policy: same-origin` (or `same-site` / `cross-origin` as needed).

All Findings

SEVERITY	HEADER	ISSUE
Critical	Content-Security-Policy	<code>'unsafe-inline'</code> allows arbitrary inline scripts — XSS protection effectively disabled.
High	Strict-Transport-Security	Strict-Transport-Security header missing.
Medium	Content-Security-Policy	base-uri not set — attackers can inject a <code><base></code> tag to redirect relative URLs.
Medium	Content-Security-Policy	frame-ancestors not set — relies on legacy X-Frame-Options.
Medium	Information Disclosure	<code>`server: Werkzeug/3.1.8 Python/3.14.6`</code> — exposes version number, enabling targeted exploit searches.
Low	Content-Security-Policy	object-src not locked to <code>'none'</code> .
Low	Content-Security-Policy	form-action not set — forms can submit anywhere.
Low	Referrer-Policy	Referrer-Policy missing — browser default leaks full URLs to other origins.
Info	Content-Security-Policy	Consider enabling <code>'upgrade-insecure-requests'</code> to auto-rewrite <code>http://</code> → <code>https://</code> .
Info	Content-Security-Policy	No CSP reporting endpoint configured — violations are invisible.
Info	Permissions-Policy	Permissions-Policy missing — features (camera, mic, geolocation, etc.) inherit defaults.
Info	Cross-Origin-Opener-Policy	Cross-Origin-Opener-Policy missing — cross-window attacks possible.
Info	Cross-Origin-Embedder-Policy	Cross-Origin-Embedder-Policy missing — required for SharedArrayBuffer/cross-origin isolation.
Info	Cross-Origin-Resource-Policy	Cross-Origin-Resource-Policy missing.

Raw Response Headers

HEADER	VALUE
Content-Security-Policy	default-src 'self'; script-src 'self' 'unsafe-inline'; style-src 'self' 'unsafe-inline'; img-src 'self' data:
X-Frame-Options	SAMEORIGIN
X-Content-Type-Options	nosniff